

external audits arranged by the foreign-based service provider or the organization.

An organization's use of a foreign-based third-party service provider (and the location of critical data and processes outside of U.S. territory) must not compromise the ability of U.S. regulatory authorities to effectively examine the organization. Thus, organizations should not establish servicing arrangements with entities where local laws or regulations would interfere with U.S. regulatory agencies' full and complete access to data or other relevant information. Any analysis of foreign laws obtained from counsel should include a discussion regarding regulatory access to information for supervisory purposes.

Appendix D: Managed Security Service Providers

Background and Purpose

A growing number of financial institutions (FIs) are partially or completely outsourcing the security management function to third parties, typically known as Managed Security Service Providers (MSSPs). FIs engage MSSPs due to increasingly sophisticated threats, cost pressures, and absence of internal expertise. The services that MSSPs provide present additional risks FIs are required to manage.

The purpose of this appendix is to identify the risks associated with the MSSP engagement and offer guidance to assist FIs in mitigating these risks. While the Federal Financial Institutions Examination Council (FFIEC) Information Technology Examination Handbook (IT Handbook) on Information Security Booklet provides related guidance, FIs should pay particular attention to risk management issues that are heightened when serviced by MSSPs. The loss of control that comes with the outsourced security function introduces an element of risk that FIs need to understand and appropriately manage. The following subsection, MSSP Engagement Criteria covers numerous engagement criteria and related contract considerations institutions should consider when engaging an MSSP.

In addition to the normal vendor management responsibilities, a successful engagement with an MSSP should include:

- A contract with mutually agreed upon Service Level Agreements (SLAs);

Strategies for ensuring transparency and accountability that include:

- o Regular communication between the FI and the MSSP on

matters including change control, problem resolution,

threat assessments, and MIS reporting,

- o Descriptions of processes for physical and logical controls over

FI data; and,

- Periodic review of the MSSP's processes, infrastructure, and control environment through offsite reviews of documentation and onsite visitations.

Types of Managed Security Services

Following are some of the many types of security-related services offered by MSSPs:

- Network Boundary Protection

Using technology such as firewalls and virtual private networks (VPNs), the MSSP protects the FI's network perimeter. The MSSP should provide device monitoring of connections to external third parties such as Internet Service Providers.

- Management of Intrusion Detection and Prevention for Networks and Hosts

Intrusion detection systems (IDS) and intrusion prevention systems (IPS) are automated services that can detect patterns in network traffic and may take action according to a rule set or pattern definition database.

- Event Log Management and Alerting

Event log management and alerting is conducted to monitor event logs generated by network devices or computer systems to centralize, filter, and provide management reports on material activity. Alerts can be set for highly sensitive events or activities.

- Anti-virus and Web Content Filtering Services

Managed antivirus protection provides organizations with malware protection that helps safeguard FIs from new threats. The malware definitions are updated frequently to help recognize the new threats.

- Patch Management and Security Software Management

MSSPs can identify and manage network security related software systems and

components requiring regular security updates; conduct compatibility testing before deployment; deploy the updates uniformly; and provide reporting on the status and effectiveness of the security software as implemented.

- Security Incident Response and Management

MSSPs can assist an organization in building an incident response team or providing a turnkey incident response in the event of a breach.

- Data Leak Prevention

MSSPs can help identify all methods of data ingress and egress, and establish systems that monitor and enforce appropriate controls.

- Secure Messaging

MSSPs can provide services to ensure the security of messages into and out of the FI.

- Information Security Consulting Services

Security consulting by MSSPs may include risk assessment, vulnerability assessment testing, penetration testing, compliance tools, education and training, and attestation services.

Description of Managed Security Services Arrangements

Managed security services arrangements can include the following four deployment models:

- Full Outsourcing: Under this model the MSSP performs the following functions autonomously.

- o Manage all network connections at customer premises;
- o Manage network platforms;
- o Update rules and thresholds over networking devices;
- o Analyze data and necessary escalation responses; and
- o Provide client reports or alerts on outcomes of the managed service.

- Co-managed: Under this model the FI and MSSP use the same infrastructure and have access rights and responsibilities on platforms.

- o Typically involves client-owned network equipment on their premises;
- o Includes common security event monitoring tools and data loss prevention solutions; and
- o IDS/IPS events are reported to the MSSP and the FI consults with the MSSP providing primary services during off hours.

- Split Processing: Under this model, the MSSP performs some functions and the FI performs others.

- o Most commonly used with firewall and network devices where the MSSP monitors log data, health and capacity with the FI pushing system updates, rules changes, or configurations;
- o Vulnerability assessment and analysis where the MSSP and FI each test applications and platforms; and
- o Sometimes used when multiple MSSPs are employed.

- **Consulting:** Consulting services provided by MSSPs can include assisting with risk assessments, initial system configuration, policy formulation, compliance (PCI, GLBA, and SOX), forensics, penetration testing, application security testing, application code review, social engineering, physical security, and management reporting.

Governance

Effective governance is fundamental for understanding and managing the risks involved when outsourcing to MSSPs. Critical areas include availability, integrity, and confidentiality of FI data. The costs to procure, operate, and manage service delivery, including review for compliance with the SLAs, should be part of the overall contract.

Risk Assessment

A risk assessment must be performed as part of, or in conjunction with, the due diligence review when an FI is considering outsourcing security services. Concerns about vendors become especially important as security practices that were traditionally conducted in-house are outsourced to an MSSP. The MSSP risk assessment should guide the FI as it develops, implements, tests, and maintains the information systems security program.

Financial Institution Requirements

Gathering necessary information internally and from the potential MSSP is necessary to identify potential threats, vulnerabilities, and controls. Documentation of the risk assessment is especially important to help ensure coordination, consistency, and standardization between the FI and the MSSP. The identification of information systems and the ranking of sensitive data and applications at the MSSP should be part of the risk assessment process. Coordination is also necessary to help ensure that vulnerabilities are identified and processes are validated through testing.

Risk Considerations for Managed Security Services

The reliance on MSSPs may significantly increase an FI's risk profile. Increased risk can arise from poor planning, lack of oversight and control, and/or poor MSSP performance or service. To control these risks, the FI should exercise appropriate due diligence prior to entering an MSSP relationship and maintain effective governance during the relationship.¹

Below are risk elements that should be considered in an FI's MSSP risk assessment.² The risks identified are relevant regardless of the type of MSSP arrangement.

Risk Elements Pertaining to Managed Security Services

- **Business Process**

According to the FI's risk profile, the following risks should be considered:

- o Decline in business reputation and customer confidence;
- o Liability under business partnership agreements;
- o False sense of security by FI management;
- o Diverse offshore legal, geo-political, and cultural risk;
- o Impact on competitive advantage when valuable intellectual property or proprietary information is stolen;
- o Reputational damage should the MSSP fail to provide the contracted service;
- o Heightened legal and regulatory issues;
- o Dependence on an outside organization for critical services;
- o Loss of the FI experience, knowledge, and skill development; and
- o Vendor financial condition decline.

Information Security Infrastructure

To optimize service availability while mitigating risks, the following should be considered:

- o Complexity of network infrastructure and deployment of agents;
- o Information security breaches and data loss;
- o Loss to the FI for failing to comply with applicable regulations

and laws;

- o Downtime due to lack of resilient MSSP infrastructure; and
- o Loss of the FI's key control requirements due to MSSP's "one size fits all" products.

- Access Management and Control

Ensure FI and MSSP user access is monitored, controlled, and assessed for inappropriate or inadequate:

- o MSSP access of FI data;
- o User access controls;
- o Segregation of duties;
- o Control and oversight of MSSP activity by the FI; and
- o Attestations of MSSP access to FI systems and data.

- Protection Against Malware

To protect the computing environment of malicious software the MSSP should have the following:

- o Current antivirus/malware protection;
- o Strong patch and/or configuration management policies and procedures;
- o Timely identification of compromised devices; and
- o Appropriate endpoint protection tools.

- Data and Media Handling

To foster adequate data and media handling protection, consider if the MSSP has:

- o Proper application configuration;
- o Secure data storage and/or processing by MSSPs;
- o Adequate access and integrity controls;
- o Appropriate encryption;
- o Adequate key management for encrypted data; and
- o Sufficient data retention.

- Application Development and Systems Integration

An FI should confirm that application development and change management are performed securely by an MSSP. The following should be considered:

- o Configuration specifications;
- o Change management processes at the MSSP and/or at the FI;
- o Logging and monitoring; and
- o Recertification of software and permissions.

- Business Continuity and Disaster Recovery

An FI should confirm that MSSPs can provide resilient services in the event of an outage or disruption. Risks that FIs should identify and address include:

- o Incompatible continuity plans and unrealistic disaster recovery planning;
- o Insufficient distance between datacenter and backup datacenter (or recovery cite) for disaster recovery;
- o Inadequate disaster recovery testing and postmortem report (Disaster recovery is not in line with disaster recovery needs.);
- o Poor communication between the FI and MSSP during a disaster; and

- o Inadequate capacity of the MSSP to service all clients during an outage.

- Incident Response Management

An FI should identify, monitor, and manage incidents in coordination with the MSSP. Risks that FIs should identify and address include:

- o Undefined roles and responsibilities between the FI and the MSSP;
- o Untimely reporting of incidents and/or data breaches;
- o Failure to take appropriate steps to contain and control the incident;
- o Failure to notify the FI's customers or regulators on FI's behalf per contract agreement;
- o Failure to perform joint incident response table-top testing with MSSPs;
- o Overdependence on the MSSP for incident response; and
- o Legal issues arising from a security incident involving both parties.

- Awareness and Training

An FI should determine that all parties are aware of and trained in processes and MIS reports. Potential risks to be addressed include:

- o Insufficient training or expertise at either the MSSP or FI; and
- o Inadequate MSSP personnel screening practices.

Request for Information and Request for Proposal